

Lightweight Secure Identity Authentication Scheme for Restricted IoT Devices

Hao Yin¹, Yi Li^{2,*}, Zichao Guo¹, Bing Li^{1,2,3,*}

¹School of Cyber Science and Engineering, Southeast University, China

²School of Microelectronics, Southeast University, China

³Wuxi RENSEU Co.Ltd, China

e-mail: {230229548@seu.edu.cn, 230229234@seu.edu.cn, bernie_seu@seu.edu.cn}

Abstract—With the wide application of IoT in many fields, IoT security has become the main reason to hinder the development of IoT. Two-way authentication of IoT devices is a basic requirement to ensure the communication security of IoT devices, however, for IoT devices with limited computation, storage and energy, the security schemes in traditional Internet cannot be applied to the restricted IoT devices. To solve these problems, this paper designs a lightweight secure authentication scheme for constrained IoT devices. The scheme uses pre-shared key (PSK) combined with temporary key generated by temporary elliptic curve (ECDHE) to generate a session key for the session, and completes the challenge answer by the session key to achieve two-way authentication of the device. The scheme is implemented by ActiveMQ and FuseSource MQTT, and experiments are conducted to compare different metrics with ECDHE-RSA cipher suite and AugMQTT authentication scheme in TLS protocol, respectively. The experimental results show that the authentication scheme designed in this paper makes up for the forward security defect in the AugMQTT authentication scheme, and the scheme is more secure; compared with the ECDHE-RSA authentication method, the execution time and CPU usage are reduced by 20% and the bandwidth usage is reduced by nearly 50%, and the scheme is more lightweight and suitable for resource-constrained IoT devices.

Keywords—edge computing, computation acceleration, security decision, resource scheduling

I. INTRODUCTION

In the era of rapid development of Internet of Things (IoT) technology, IoT devices which greatly facilitating people's lives, are widely used in various fields, such as home automation, intelligent transportation, smart cities, etc.

However, with the continuous increase of IoT access devices, the data collected and transmitted through IoT devices is growing exponentially, and the security issues of IoT device communication are also facing severe challenges [1]. Identity authentication of IoT devices is a fundamental requirement for secure communication in the Internet of Things. Without an identity authentication mechanism, attackers can easily disguise themselves as IoT client devices and send malicious data to servers. However, due to the limited computing, storage, and energy issues of IoT devices, traditional algorithm authentication schemes in the Internet are difficult to apply in IoT environments.

The TLS protocol, which is most commonly used in the Internet, can safely and effectively achieve bidirectional authentication between communication parties. However, the certificate authentication process is complex and requires frequent storage, invocation, and verification of certificates, occupying a large amount of storage and computing costs on devices, making it difficult for restricted devices to support the TLS protocol. Many schemes have used the identity authentication method based on password token or pre Shared secret PSK. Although this method is lightweight, its security is poor. Static token or PSK cannot provide forward security for data. Therefore, it is necessary to design a lightweight and secure solution to address the issue of bidirectional authentication between restricted IoT devices.

The protocols of Message Queuing Telemetry Transport (MQTT) [2] and the Constrained Application Protocol (CoAP) are both oriented the restricted network. The characteristics of the two protocols have been compared and analyzed in the literature [3]. Compared with the CoAP of the point-to-point mode [4], the MQTT based on the Publish-subscribe mode shown in Figure 1 have become the most mainstream IoT messaging protocol in today's Internet of Things for its lightweight, flexible, strong scalability and other characteristics. This is suitable for large-scale communication such as one-to-many or many-to-many wireless sensor networks.

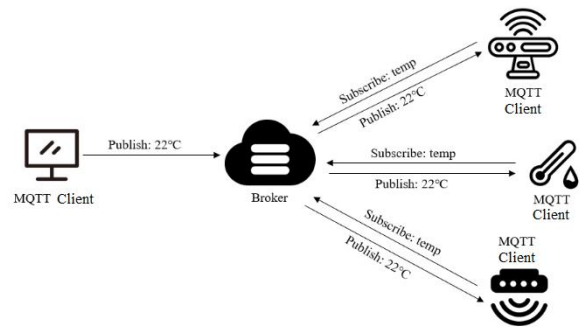


Fig. 1. MQTT publish subscribe mode

Therefore, combining the above contents, this paper designs a lightweight security identity authentication scheme suitable for restricted IoT devices. By using the pre Shared secret PSK and the temporary key generated by the elliptic curve ECDHE algorithm, this session key is generated, and the two-way

authentication of the device is realized by completing the challenge response through the session key, and this scheme is implemented on the MQTT protocol. The main contributions of this research are as follows:

- In response to the limited resources of IoT devices, this article designs a lightweight and secure bidirectional authentication scheme for restricted devices. This scheme has low execution cost and can safely and effectively achieve bidirectional identity authentication between restricted devices. Each session generates a one-time encrypted session key, which is used to complete the challenge response to achieve identity authentication, ensuring data forward security.
- The experiment was implemented through ActiveMQ and FuseSource, simulating communication between clients and servers in a simulated restricted device, and testing the feasibility of the solution. Test the performance of the solution from three indicators: execution time, CPU usage, and bandwidth consumption.
- This article implements the AugMQTT scheme [5] and the ECDHE-RSA certificate authentication method used in the paper [6], and compares the security and performance with the lightweight secure identity authentication scheme proposed in this article. Comparative experiments have shown that this scheme is more secure compared with the AugMQTT authentication method and can ensure data forward security. Compared to the traditional certificate ECDHE-RSA authentication method, it consumes less resources.

The rest of the paper is organized as follows: The second section provides relevant work. The third section provides a detailed description of the lightweight secure identity authentication scheme process designed in this article. The fourth section briefly describes the implementation process of the scheme, and the fifth section compares the performance and security of AugMQTT and ECDHE-RSA schemes with this scheme. Finally, summarize the entire article in Section 6.

II. RELATED WORK

In restricted IoT devices, Bhawiyuga et al. [7] proposed a token IoT device authentication scheme based on the mainstream MQTT protocol. This scheme introduces an additional JWT token authentication server in the MQTT infrastructure, which generates a token for each registered client and complete authentication with certificate replaced. The token can be used for subsequent request connections. This solution reduces the cost of storing certificates on the proxy server, but it requires the introduction of additional device overhead and ensures that the intermediate authentication server must be trusted.

Xu [8] and Song [9] proposed using the Diffie Herman (DH) algorithm to achieve mutual authentication between users. Shin et al. [10] proposed a simple and lightweight security framework AugMQTT, AugPAKE protocol used in this scheme [11] is an improvement of the DH key negotiation algorithm. The client needs to register with the proxy to obtain the password before authentication, and the communication parties can complete identity authentication by verifying the public verification

credentials created by the password. The MQTT-Auth proposed by Calabretta et al. [12] also uses the AugPAKE protocol for identity authentication. The AugPAKE protocol is a lightweight implementation of the SSL/TLS authentication protocol, which can solve problems such as complex handshake process and difficult certificate management in the SSL/TLS protocol. However, the AugPAKE protocol still has a flaw in the DH algorithm, which cannot guarantee forward security.

Yeh et al. [13] proposed a user authentication and key management scheme based on an efficient Elliptic Curve Cryptography (ECC) algorithm, which is lightweight and efficient and can be used for restricted IoT devices. Kalra et al. [14] used a combination of HTTP cookies and ECC to ensure the communication security of IoT devices. Similarly, Kumar [15] and others use ECC to achieve anonymous secure communication for Key exchange between ECS and RFID tags in cloud computing networks.

Singh [16] proposed an Attribute-based encryption (ABE) method based on elliptic curves, where only attributes registered on the client can complete the data decryption. This method not only achieves identity authentication but also completes access control functions. However, ABE is not suitable for resource limited devices, the encryption cost of pairing operations increases rapidly with the increase of attributes [17].

Static PSK has been used in literature [18-19] to ensure secure authentication between end-to-end devices. Although static PSK authentication is lighter than certificate authentication, but its security is lower. Using static PSK for encryption also cannot guarantee the forward security of data. Other studies [20-21] use OAuth protocol or Identity based Cryptosystem (IBC) to achieve identity authentication. These authentication processes are similar to JWT authentication, and need to introduce a third-party token server or private key generator (PKG) to complete the authentication. The authentication process must ensure the third-party server trusted.

Through the above comparative study of existing IoT lightweight schemes, it is found that most of the authentication schemes can be divided into two categories. One is saving relevant information such as pre Shared secret, password, user identity information and so on in the server during the registration process instead of certificates to complete authentication, thus avoiding the cost of managing and verifying certificates. The calculation and storage costs are small, and the implementation and deployment are simple. Moreover, due to the pre sharing of device keys, it directly saves the key negotiation process in the communication process and is suitable for resource limited IoT devices. However, this method has forward security issues because the registered password or pre shared secret cannot be changed in the whole process. The second type of solution sets the timeliness of the password. Once the password expires, a new password needs to be obtained for authentication. Although this approach solves the forward security problem, it requires the introduction of third-party devices to generate instant passwords. In summary, the work of this article aims to design a lightweight secure identity authentication scheme that does not introduce third-party devices to ensure secure communication with restricted devices.

III. SCHEME DESIGN

Table 1 shows the list of relevant parameters involved in this scheme, which is the same as most IoT security authentication methods. The identity authentication scheme is divided into two stages, namely the registration stage and the identity verification stage.

In the registration phase, communication devices first register their identity information and corresponding PSK in a secure way on the server, such as through offline registration or directly writing the registered key into the hardware when the device leaves the factory. The proxy server stores the device's registered identity information and corresponding PSK in the database.

TABLE I. AUTHENTICATION SCHEME PARAMETERS

Sign	Description
ID	Device identity information
d	Private key
Q	Public key
PSK	Pre shared secret key
T	Challenge response text
SK	Temporary session key
K	Session key
E	Encryption operation
D	Decryption operation
X	Client response text
Y	Server response text
t	Time stamp
C	Client
S	Server

In the identity authentication phase, in order to solve the forward problem of the static PSK in the authentication scheme based on the pre shared secret, the scheme introduces the ECDHE key agreement algorithm. The principle and characteristics of the ECDH algorithm are introduced in detail in Chapter 2.2.3 Key agreement algorithm. The security of the ECDH algorithm depends on the difficulty of solving Discrete logarithm on the elliptic curve and the DH algorithm. On the basis of the DH algorithm, it is difficult for attackers to crack the private key, and the algorithm cost is small, Very suitable for restricted IoT devices. The ECDHE algorithm is a derivative of the ECDH algorithm, which renegotiates the session key for each session, ensuring that the key is encrypted once. However, ECDH algorithm can not verify the identity of the communication party, and there is a risk of Man-in-the-middle attack. In response to the problems in the above scheme, this scheme combines PSK authentication with ECDHE key negotiation algorithm to achieve lightweight authentication process for IoT devices, at the same time negotiate the session key for this session. The specific process is shown as the device identity authentication process in Figure 2.

Step 1: Device C generates ECDH algorithm related parameters and registration identity information ID_i , send it to

server S. At the same time generate a random number d_c as private key and public key $Q_c = d_c G$;

Step 2: Server S receives the information ID_i and ECDH algorithm parameters sent from device C, query the key pool to determine whether ID_i is legal. If it is legal, obtain the corresponding pre Shared secret PSK_i , generate the private key d_s , public key Q_s and challenge text T_s on server. Send text T_s and public key Q_s to device C, where $Q_s = d_s G$. On the contrary, the server rejects the connection;

Step 3: After receiving the challenge from server S, device C generates a temporary key SK, text T_c for verifying server identity and the current session key K through the ECDH negotiation algorithm, and then encrypt the text T_s and T_c through the key K. Obtain response X, and finally send the device public key Q_c and response X to server S. Among them:

$$SK = d_c * Q_s \quad (1)$$

$$K = SK \oplus PSK_i \quad (2)$$

$$X = E(K, T_s || T_c) \quad (3)$$

Step 4: The server generates a temporary key SK and session key K, decrypts the response X sent from device C, and obtains the challenge text T_s and T_c , verify if T_s' is the same with T_s , if it is same, then the device authentication passes and a response text $Y = E(K, T_c)$ is generated and sent to device C. On the contrary, reject the connection;

Step 5: The device decrypts the Y sent from the server and obtains the text T_c' , verify if text T_c' and T_c is the same? If it is the same, the server authentication passes, and if it is not, the connection is disconnected.

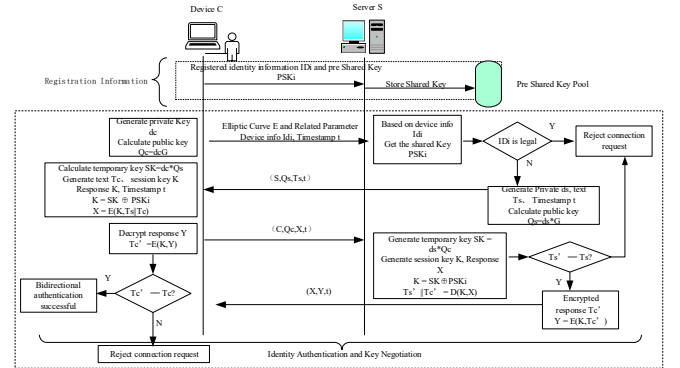


Fig 2. Identity authentication and key negotiation phase flow

The lightweight identity authentication scheme designed in this paper combines the pre Shared secret with the ECDHE based key agreement algorithm. Compared with the traditional TLS protocol, certificate authentication is a lightweight authentication scheme. It completes the key agreement process while authenticating identity, reduces the number of interactions in the process of identity authentication and key agreement, and saves the cost of communication process. Although the PSK used in identity authentication is static, due to the fact that the ECDHE algorithm renegotiates the temporary key SK every session, the challenge response and encrypted session key K is obtained through the XOR of PSK and SK, ensuring that

different encryption keys are used for each session and achieving forward security of communication data. At the same time, due to the pre sharing of keys within the device, by encrypting and decrypting the challenge response text, as long as the challenge is successful, the identity of the device can be verified, making up for the identity authentication problem of the ECDHE key negotiation algorithm.

IV. SOLUTION IMPLEMENTATION

In order to verify the lightweight and security of this scheme, this chapter will simulate the communication between IoT clients and servers in a simulated environment. During the communication process, the MQTT protocol analyzed in section 2.1.1, which is suitable, mainstream, and lightweight for IoT devices, was used as the communication protocol for this experiment. The Linux virtual machine system parameters were adjusted through VMWare to simulate resource constrained servers. ActiveMQ was installed as the broker in the MQTT service on the server, and the user information during the registration process was recorded. The pre Shared secret and the session key negotiated between different clients are stored locally. The local device and server simultaneously install FuseSource as an MQTT client to achieve two-way communication and simulate the process of identity authentication and key negotiation. The server and device parameters are shown in Table 2.

TABLE II. CLIENT AND SERVER SYSTEM PARAMETERS

Parameter	Client	Server
CPU	Intel Core i5-7200U	Intel Core i5-7200U
Memory	8GB	1GB
OS	Windows 10	CenOS Linux 7
Java Version	11	11
MQTT Version	3.1	3.1
Client	fuseSource mqtt-client 1.6	fuseSource mqtt-client 1.6
Broker		Apache ActiveMQ 5.15.2

Using ActiveMQ as an MQTT proxy can provide stable and reliable message transmission services, while using FuseSource on the client can further customize message processing rules. Utilize the Listener interface provided by FuseSource and the BrokerFilter interface provided by ActiveMQ to extend and customize message processing rules, such as rewriting onPublish and addConsumer methods to implement message processing logic when connecting to the client and receiving messages, as well as when proxy the client.

Specifically, each IoT device as a client must first register the client's identity information with the agent and complete the identity authentication process before sending or receiving messages. In the simulation experiment, it is assumed that the IoT device has completed the registration process of identity information and pre shared key offline, and saved the corresponding message in the broker server. The identity authentication process is carried out through the MQTT protocol.

Through the scheme analysis in section 4.2, the identity authentication process is defined into five stages, namely CLIENT_PREPARATION, SERVER_CHALLENGE, CLIENT_RESPONSE, SERVER_RESPONSE and COMPLETE. The corresponding content for each stage is shown in Table 3.

Throughout the entire identity authentication process, all messages and corresponding stages are encapsulated in the PUBLISH message of MQTT for transmission. Broker will publish a public theme device_auth, all clients who connect to the broker publish identity authentication information to the topic to complete communication with the broker. Broker continuously listens to the topic device_auth message, obtain the client identity ClientID of the published message and the authentication stage of the client based on the message within the topic, and update and save this information locally for subsequent authentication processes.

TABLE III. THE FIVE STAGES DEFINED IN THE IMPLEMENTATION PROCESS AND THEIR CORRESPONDING TRANSMISSION CONTENT

Phase	Transferring Content
CLIENT_PREPARATION	Client identity C, Elliptic curve parameters, Timestamp t
SERVER_CHALLENGE	(S, Q_s, T_s, t)
CLIENT_RESPONSE	(C, Q_c, X, t)
SERVER_RESPONSE	(S, Y, t)
COMPLETE	-

When the client and broker have established a connection, submit it to the topic device_auth to publish the first CLIENT_PREPARATION message indicating preparation for authentication. The client will generate and automatically subscribe to a dedicated temporary theme auth_clientId, the broker server communicates with the client by publishing a message to the temporary topic. The specific communication process is shown in Figure 2.

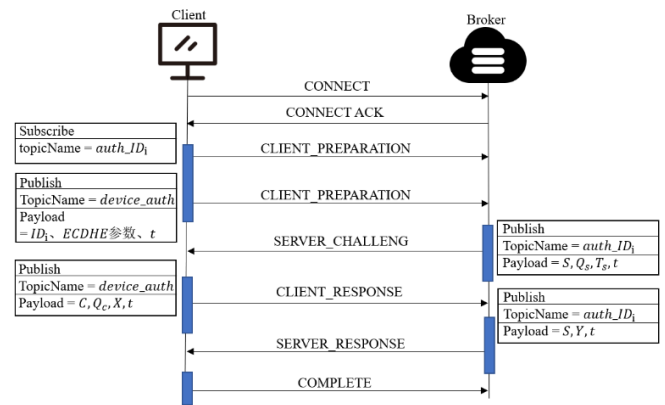


Fig. 3. Identity authentication scheme communication process

V. PERFORMANCE AND EXPERIMENTAL ANALYSIS

In this section, this article first introduces the experimental environment and performance analysis tools for comparative

experiments. Then, this article compares the ECDHE-RSA certificate authentication scheme and AugMQTT scheme with three indicators: scheme execution time, CPU usage, and bandwidth consumption. Finally, the security of this scheme and other schemes is analyzed.

A. Performance Analysis

After functional testing and security analysis of the identity authentication scheme, lightness is also one of the important factors determining whether the scheme can be applied to restricted IoT devices. Due to the effective computing, storage, and energy performance of the vast majority of IoT devices, traditional Internet security schemes cannot be applied to IoT devices, that is the reason many IoT devices do not provide any protection for transmitted data. To ensure the lightness of the scheme, the experiment combines the proposed scheme with the AugMQTT authentication scheme and the TLS protocol based ECDHE_RSA used in scheme [6] to compare and new performance evaluations were conducted using four indicators: execution time, CPU utilization, bandwidth consumption, and energy consumption when successfully connecting to the Broker server and completing identity authentication in three scenarios. In order to avoid network fluctuations, the average values of the three schemes were taken for comparison after 10 experiments. It should be noted that, due to the superior performance of simulation experimental equipment compared to the actual resource constrained IoT, the performance indicators obtained from the experiment are relatively good, and the comparative experiment focuses more on the performance differences between the three schemes.

In order to complete the comparison of solutions, it is first necessary to prepare the experimental environment for the server in paper [6], and install OpenSSL to implement the ECDHE-RSA certificate authentication method in the TLS protocol. The AugMQTT scheme was implemented using ActiveMQ and FuseSource. In addition to this, the comparative experiment use perf performance analysis tool to monitor the CPU utilization of restricted devices during the execution of different schemes on Linux servers. WireShark was used to monitor the transmission time and size of packets when establishing a connection between the client and agent after identity authentication, and to calculate bandwidth consumption. The experimental results are shown in Table 4.

TABLE IV. COMPARATIVE AVERAGE RESULTS OF THREE IOT SECURITY SOLUTIONS

<i>Performance Indicators</i>	<i>This Scheme</i>	<i>[5]</i>	<i>[6]</i>
Execution Time (ms)	1984	1925	2621
CPU Occupancy Rate (%)	22	21	31
Bandwidth Consumption (bps)	5894	5357	11265

Due to the secure and efficient IoT solution proposed in paper [6] being based on the TLS protocol, certificates need to be transmitted between clients and agents, and RSA signature is required to verify the validity of certificates to complete identity verification. RSA has high requirements for computational complexity and performance, resulting in the highest execution

time, CPU usage, and bandwidth consumption. The scheme [5] is based on the AugPAKE protocol to achieve identity authentication. The detailed principle can be seen in RFC6628 [11]. The execution process of SafeMQTT proposed in this article requires a total of five handshakes, while AugMQTT requires six handshakes. SafeMQTT saves one handshake time compared to AugMQTT, but SafeMQTT needs to transmit text during the authentication process and encrypt and decrypt the text to achieve identity authentication. AugMQTT only needs to compare the hash of relevant information, compared with the AugMQTT scheme, the execution time of SafeMQTT is basically the same, the amount of data transmitted is more, and the bandwidth consumption is higher.

B. Safety Analysis

This paper proposes a lightweight identity authentication scheme based on pre shared secret and temporary elliptic curve. This scheme can effectively generate a session key for client and agent, and use the session key to complete the challenge response to achieve two-way identity authentication between client and agent. In addition to the identity authentication function, this scheme can also resist Man-in-the-middle attack and Replay attack to ensure the forward security of communication data. The specific security analysis of this scheme is as follows.

1. Identity authentication

When the IoT device is connected to the server, it needs to use the pre Shared secret that represents the client's identity to participate in the negotiation of the session key, and use the negotiated session key to complete the encryption of the challenge text sent by the communicator. The communicator decrypts the ciphertext and compares it with the text sent. If it is the same, the authentication is successful. Since the attacker could not obtain the pre Shared secret, the attacker could not normally complete the challenge response, and the identity authentication failed. In 4.4.2 function test, it is verified that if an attacker masquerades as a communicator and forges the pre Shared secret to participate in authentication, the authentication fails and the connection is interrupted due to the wrong session key.

2. Resist Man-in-the-middle attack

The intermediary refers to the attacker who disguises himself as one of the communication parties and interferes with the normal communication between the client and the server, without the knowledge of the communication parties, thereby stealing the communication content. In this scheme, if the attacker disguises himself as any communicating party to communicate with the other party, due to the need to encrypt and decrypt the text during the identity verification process, if the intermediary A disguises himself as the server S and sends the text Ta to the client C. The client generates the session key using the registered pre Shared secret to generate the text Tc and encrypt Tc || Ta and sends it to intermediary A. Because the intermediary does not know that the pre Shared secret cannot generate a session key, intermediary can not decrypt the client text Tc, neither can encrypt it to send back to client C, so it is not possible to forge identity. Similarly, attackers cannot disguise themselves as clients to communicate with the server.

Therefore, the scheme can effectively resist Man-in-the-middle attack.

3. Anti Replay attack

When the client and server communicate with each other for identity authentication, they both need to carry a timestamp t to determine whether the received message is within a reasonable time delay to ensure that the message will not be replayed. If the attacker intercepts a message that has completed authentication and sends it to the communicating party, but the timestamp of the message has exceeded the delay requirement of the message, the communicating party directly disconnects from it.

4. Integrity protection

Integrity protection ensures that messages are not tampered by attackers during transmission. However, this scheme achieves identity authentication through a challenge response to the text, which requires ensuring that the decrypted ciphertext must be consistent with the sent text in order to consider authentication successful. Therefore, when the text sent or received is tampered with an attacker, the authentication process cannot be completed. Therefore, once the transmitted content is modified by an attacker, it can be promptly discovered by the passing party, so the scheme can ensure the integrity of the message.

5. Forward safety

This scheme uses the challenge response mechanism based on the pre Shared secret to complete the identity authentication process between the server and the client. The pre Shared secret can avoid heavy certificate verification and management costs, which is a lightweight identity authentication process. However, the static pre Shared secret cannot guarantee the forward security of communication. If the static pre Shared secret is disclosed in the future, an attacker can masquerade as a client to connect to the server. This scheme combines the pre Shared secret and the key negotiated by ECDHE, uses the negotiated session key one at a time to complete the challenge response. Even if the attacker cracked the key for one time, he cannot forge the passer side to complete other sessions, which can effectively ensure forward security.

TABLE V. SECURITY COMPARISON BETWEEN THIS SCHEME AND OTHER SCHEMES

	<i>This Scheme</i>	[5]	[6]	[7]	[22]
Lightweight	√	√	×	×	√
Bidirectional Identity Authentication	√	√	√	√	√
Man-in-the-Middle Attack	√	√	√	×	×
Replay Attack	√	×	√	×	×
Key Negotiation	√	√	√	×	×
Forward Safety	√	×	√	√	×

As shown in Table 5, the security comparison between this scheme and existing IoT authentication schemes is presented. Scheme [7] completes identity authentication through tokens and sets an effective time for tokens to ensure forward security of the session. However, it introduces the cost of third-party

institutions and lacks a secure data transmission mechanism. Scheme [5] belongs to a lightweight identity authentication scheme, but due to the static registration code, there are forward security issues with the data, and there is also a lack of secure data transmission schemes to ensure the confidentiality and integrity of the data. Scheme [22] uses a static PSK key for identity verification, providing a complete algorithm for data confidentiality and integrity. However, like Scheme [6], it cannot guarantee forward security of the data, and neither Scheme [5,7,22] considers the issue of replay attacks. Solution [6] is ECDHE_RSA based on TLS protocol, although can complete identity authentication, the implementation process is too complex and cumbersome, not suitable for restricted IoT devices.

C. Experimental results summary

In performance experiments, compared to the AugMQTT proposed in Scheme [5], this scheme has basically the same execution time and CPU usage, and higher bandwidth consumption. However, in terms of security, Scheme [5] has data forward security issues during the authentication process, the scheme in this paper has higher security than Scheme [5]. Therefore, the lightweight secure identity authentication scheme designed in this article has faster execution speed and less bandwidth consumption compared to scheme [6]. Although the execution efficiency is basically the same as scheme [5], it has higher security and can meet the needs of secure identity authentication and data communication between resource and computing limited IoT devices.

VI. SUMMARY AND OUTLOOK

Due to the inevitable steps of secure communication during authentication, this article analyzes and studies lightweight secure identity authentication schemes between computing and resource constrained IoT devices and servers. A lightweight identity authentication scheme suitable for this scenario is designed. Finally, performance evaluation is conducted by comparing the ECDHE-RSA certificate authentication scheme in AugMQTT and TLS protocols in simulation experiments. The experimental results show that the lightweight identity authentication scheme designed in this paper based on the pre Shared secret PSK and ECDHE key agreement algorithm can safely achieve two-way identity authentication between IoT devices, and the scheme execution cost is smaller than traditional certificates. The authentication scheme designed in this paper belongs to a lightweight identity authentication scheme.

This scheme mainly involves negotiating session keys between IoT clients and servers for challenge response to complete bidirectional identity authentication. However, in the scheme, the server is visible to the communication data content, and if the proxy is attacked by security, the data will still be leaked. In future work, we can consider how to forward data in ciphertext without affecting normal data communication between clients, such as using proxy re encryption technology to ensure data is not visible to the server.

ACKNOWLEDGMENT

This work has been supported by 2022 Jiangsu Transportation Technology and Achievement Transformation

Project (Intelligent transportation outfield intelligent facility network security protection system and technical requirements. Nos. 2022G10 / JSZC-321200-JSJW-C2022-0070). And this work has been supported by National Natural Science Foundation of China 62174150.

REFERENCES

- [1] R. Gurunath, M. Agarwal, A. Nandi, et al. An overview: security issue in IoT network[C]//2018 2nd international conference on I-SMAC (IoT in social, Mobile, analytics and cloud)(I-SMAC) I-SMAC (IoT in social, Mobile, analytics and cloud)(I-SMAC), 2018 2nd international conference on. IEEE, 2018: 104-107.
- [2] M. B. Yassein, M. Q. Shatnawi, S. Aljwameh and R. Al-Hatmi, "Internet of Things: Survey and open issues of MQTT protocol," 2017 International Conference on Engineering & MIS (ICEMIS), 2017, pp. 1-6, doi: 10.1109/ICEMIS.2017.8273112.
- [3] N. Naik, "Choice of effective messaging protocols for IoT systems: MQTT, CoAP, AMQP and HTTP," 2017 IEEE International Systems Engineering Symposium (ISSE), 2017, pp. 1-7, doi: 10.1109/SysEng.2017.8088251.
- [4] S. -P. Hsu, Y. -M. Chang, S. -R. Yang and P. -H. Hsieh, "The Design and Implementation of a Lightweight CoAP-based IoT Framework with Smart Contract Security Guarantee," 2020 12th International Symposium on Communication Systems, Networks and Digital Signal Processing (CSNDSP), 2020, pp. 1-6, doi: 10.1109/CSNDSP49049.2020.9249596.
- [5] S. Shin, K. Kobara, Chia-Chuan Chuang and Weicheng Huang, "A security framework for MQTT," 2016 IEEE Conference on Communications and Network Security (CNS), 2016, pp. 432-436, doi: 10.1109/CNS.2016.7860532.
- [6] Z. Wang, H. Chen, W. Wu, Client-aware negotiation for secure and efficient data transmission, *Energies* 13 (2020) 5777.
- [7] A. Bhawiyuga, M. Data and A. Warda, "Architectural design of token based authentication of MQTT protocol in constrained IoT device," 2017 11th International Conference on Telecommunication Systems Services and Applications (TSSA), 2017, pp. 1-4, doi: 10.1109/TSSA.2017.8272933.
- [8] Xu J, Zhu W T, Feng D G. An improved smart card based password authentication scheme with provable security[J]. *Computer Standards & Interfaces*, 2009, 31(4):723-728
- [9] Song R. Advanced smart card based password authentication protocol[J]. *Computer Standards & Interfaces*, 2010, 32(5-6):321-325.
- [10] RFC 6628 Efficient Augmented Password-Only Authentication and Key Exchange for IKEv2
- [11] M. Calabretta, R. Pecori and L. Veltri, "A Token-based Protocol for Securing MQTT Communications," 2018 26th International Conference on Software, Telecommunications and Computer Networks (SoftCOM), 2018, pp. 1-6, doi: 10.23919/SOFTCOM.2018.8555834.
- [12] M. Calabretta, R. Pecori and L. Veltri, "A Token-based Protocol for Securing MQTT Communications," 2018 26th International Conference on Software, Telecommunications and Computer Networks (SoftCOM), 2018, pp. 1-6, doi: 10.23919/SOFTCOM.2018.8555834.
- [13] Telecommunications and Computer Networks (SoftCOM), 2018, pp. 1-6, doi: 10.23919/SOFTCOM.2018.8555834.
- [14] Yeh HL, Chen TH, Liu PC, Kim TH, Wei HW. A secured authentication protocol for wireless sensor networks using elliptic curves cryptography[J]. *Sensors* 2011(11):4767-79.
- [15] Kalra S, Sood S K. Secure authentication scheme for IoT and cloud servers[J]. *Pervasive and Mobile Computing*, 2015, 24: 210-223.
- [16] Kumar V, Ahmad M, Mishra D, et al. RSEAP: RFID based secure and efficient authentication protocol for vehicular cloud computing[J]. *Vehicular Communications*, 2020, 22: 100213.
- [17] M. Singh, M. A. Rajan, V. L. Shivraj and P. Balamuralidhar, "Secure MQTT for Internet of Things (IoT)," 2015 Fifth International Conference on Communication Systems and Network Technologies, 2015, pp. 746-751, doi: 10.1109/CSNT.2015.16.
- [18] B. Girgenti, P. Perazzo, C. Vallati, F. Righetti, G. Dini, and G. Anastasi, "On the Feasibility of Attribute-Based Encryption on Constrained IoT Devices for Smart Systems," in *Proc. 2019 IEEE International Conference on Smart Computing*, pp. 225-232, Washington D.C., U.S.A., Jun. 12-15, 2019.
- [19] B. Mukherjee, S. Wang, W. Lu, R.L. Neupane, D. Dunn, Y. Ren, Q. Su, P. Callyam, Flexible IoT security middleware for end-to-end cloud-fog communication, *Future Gener. Comput. Syst.* 87 (2018) 688-703
- [20] S. Forsström, U. Jennehag, X. Guan, A plain low threshold IoT platform for enabling new IoT products from SMEs, in: 2020 IEEE International Workshop on Metrology for Industry 4.0 & IoT, 2020, pp. 390-394.
- [21] Ö. Yerlikaya and G. Dalkılıç, "Authentication and Authorization Mechanism on Message Queue Telemetry Transport Protocol," 2018 3rd International Conference on Computer Science and Engineering (UBMK), 2018, pp. 145-150, doi: 10.1109/UBMK.2018.8566599.
- [22] A. Niruntasukrat, C. Issariyapat, P. Pongpaibool, K. Meesublak, P. Aiumsupugul and A. Panya, "Authorization mechanism for MQTT-based Internet of Things," 2016 IEEE International Conference on Communications Workshops (ICC), 2016, pp. 290-295, doi: 10.1109/ICCW.2016.7503802.